Vendor Risk Checklist

for Community Banks and Credit Unions

Version 1.2 · November 2026 · Jailton de Andrade Raimundo · Tech Finance Advisor (techfinanceadvisor.com)

Why this checklist

Community banks and credit unions depend on a small number of technology providers for core processing, digital banking and payments. When one provider fails, many institutions can be affected at once: in late 2023, a ransomware attack on a single technology provider (it began on November 26, 2023, according to the NCUA) disrupted services at roughly 60 credit unions. Large banks have dedicated vendor-management teams; most small institutions do not.

This checklist turns the U.S. interagency third-party risk guidance (2023), the agencies' guide for community banks (2024), the 2026 proposed update and the September 2026 joint statement on core service providers into 45 practical questions, organized by the six stages of a provider relationship. It also covers accessibility for customers who are blind, deaf or hard of hearing, or have speech disabilities.

How to use it

- Use it before signing, at renewal, and once a year for your highest-risk providers (core, digital banking, payments).
- A "no" is not a failure: it is a gap to discuss with the provider, document, and track until closed.
- Scale the effort to the potential harm: not every provider needs every question.
- A control that exists is not the same as evidence you can rely on: for your highest-risk providers, check whether the evidence behind each answer supports the decision you are making (to sign, renew or keep relying on the provider).

1. Planning

☐ **1.** Which customer data, systems and payment flows will this provider touch?

☐ **2.** If this provider is down for one business day, what stops working for customers?

☐ **3.** How many realistic alternative providers exist, and how hard would it be to switch?

☐ **4.** Does this service depend on other providers (cloud, data centers, telecommunications, subcontractors), and do any of our other critical providers depend on the same ones?

☐ **5.** Who inside the institution will own this relationship, and do they have time and skills for it?

☐ **6.** What would the exit cost (time, money, conversion work) if we had to leave in three years?

☐ **7.** Is the level of oversight we plan proportionate to the potential harm?

☐ **8.** Can customers who are blind, deaf or hard of hearing, or have speech disabilities complete key tasks with this service (open an account, pay, get support), including support channels beyond voice such as chat, text and relay services?

2. Due diligence and selection

☐ **9.** Will the provider share recent independent security reports (for example, SOC 2 Type II) and penetration test summaries, and do the reports' scope, coverage period and exceptions actually cover the services we use?

☐ **10.** How many security incidents and outages has the provider had in the last 24 months, and how were they handled?

☐ **11.** Which components of the product are at or near end of support, and what is the upgrade roadmap?

☐ **12.** Is the provider financially stable enough to support us for the full contract term?

☐ **13.** Which subcontractors (fourth parties) will handle our data, and where?

☐ **14.** Can we talk to two or three peer institutions of similar size that use this provider?

☐ **15.** Are pricing and billing clear enough that we can reconcile every invoice line to a service we receive?

☐ **16.** For customer-facing products, does the provider publish an Accessibility Conformance Report (VPAT/ACR) stating which WCAG version and level it meets (for example, WCAG 2.1 or 2.2 AA)?

☐ **17.** Have the screens been tested with screen readers and keyboard-only navigation, ideally by people with disabilities?

3. Contract

☐ **18.** Does the contract state clearly that the institution owns its data?

☐ **19.** Can we export all our data, at any time, in a documented and usable format, at a defined cost?

☐ **20.** Are deconversion fees and exit assistance defined in advance, not left open?

☐ **21.** Are SLAs measurable (availability, response and recovery times) with consequences if missed?

☐ **22.** How fast must the provider notify us of a security incident or major outage?

☐ **23.** Is there a limit on back-billing (retroactive charges for items missing from prior invoices)?

☐ **24.** Can other providers integrate with the platform through documented APIs, without excessive fees or restrictions?

☐ **25.** Do we have audit rights, and will the provider cooperate with regulators?

☐ **26.** Does the contract require customer-facing products to meet a defined accessibility standard, with a deadline to fix accessibility defects?

☐ **27.** Are statements, notices and disclosures available in accessible formats (screen-reader-friendly documents, large print, captioned video)?

4. Oversight and accountability

☐ **28.** Does the board or a senior committee know which provider relationships carry the highest risk?

☐ **29.** Is there a single, current inventory of providers, with risk level and owner for each one?

☐ **30.** How often are high-risk relationships reviewed, and who signs off?

☐ **31.** Are issues found with a provider tracked until they are closed, and if a material issue stays open, who has authority to accept it, based on what evidence, and until when?

☐ **32.** Is the institution's own staff trained to manage the provider, rather than depending on the provider's own staff?

5. Ongoing monitoring

☐ **33.** Do we track availability against the agreed SLA every month, with our own measurements?

☐ **34.** Do we track incident notification times and root-cause reports from the provider?

☐ **35.** Have recovery and failover been tested in the last 12 months, and did the actual recovery time and data loss meet our own requirements (RTO and RPO)?

☐ **36.** Do we review new end-of-support components and security advisories that affect us?

☐ **37.** Do invoices still reconcile with the services we receive?

☐ **38.** Have the provider's subcontractors, ownership or financial condition changed, and is there a defined trigger to revisit the original risk assessment when they do?

☐ **39.** Do we track accessibility complaints and defects, and does each new release keep the agreed accessibility level?

6. Termination and exit

☐ **40.** Have we ever tested a full data extract, and could another team load it without the provider's help?

☐ **41.** Are the interfaces documented well enough for another provider to rebuild them?

☐ **42.** Is there a written transition plan with timelines, responsibilities and customer communication?

☐ **43.** Can we run old and new systems in parallel during the transition, and for how long?

☐ **44.** What happens to our data at the provider after exit (return, deletion, confirmation)?

☐ **45.** Could we exit in an emergency (provider failure or major breach), not only at renewal?

Practitioner feedback

“A thoughtful and practical resource, particularly for smaller institutions that may not have dedicated third-party risk teams.” — Neil P. Osnato, Founder, Persistence Analytics Group LLC

Shared as professional feedback. It is not an independent certification or endorsement of the checklist's regulatory completeness.

Acknowledgments

Version 1.2 incorporates suggestions from Neil P. Osnato, Founder, Persistence Analytics Group LLC, Decision Assurance™, on questions 4, 9, 31, 35 and 38 and on the "How to use it" section. Any remaining errors are the author's.

Disclaimer

This checklist is a free, non-binding operational aid based on public U.S. interagency guidance. It is not legal advice and does not replace an institution's own risk assessment. Free to use and share with attribution (CC BY 4.0).

Sources

- Interagency Guidance on Third-Party Relationships: Risk Management (June 2023).
- Third-Party Risk Management: A Guide for Community Banks (Federal Reserve, FDIC and OCC, May 2024).
- NCUA, Cybersecurity and Credit Union System Resilience, report to Congress (June 2024).
- Proposed Third-Party Risk Management Guidance, 91 FR 58536 (September 15, 2026): federalregister.gov/documents/2026/09/15/2026-18859
- Joint Statement on Community Banks' Engagement with Core Service Providers (September 11, 2026): federalreserve.gov/newsevents/pressreleases/files/bcreg20260911a3.pdf

- U.S. Department of Justice, Guidance on Web Accessibility and the ADA (March 2022): ada.gov/resources/web-guidance

Version history

- 1.2 (November 2026): refined questions 4, 9, 31, 35 and 38 and added a note on evidence to "How to use it", based on practitioner feedback; added practitioner feedback and acknowledgments.
- 1.1 (November 2026): corrected the date of the 2023 incident and added two sources.
- 1.0 (November 2026): first public version.